

BUG-PRODUCT-005: API sản phẩm thiếu kiểm tra xác thực (401) và phân quyền (403)

Found by Test Case

TC-PRODUCT-013, TC-PRODUCT-014

Requirement liên quan

FR-12 / SEC-02, SEC-03 (Phân quyền API — chỉ Admin mới được tạo/sửa/xóa sản phẩm)

Severity / Priority

Blocker / P0

Environment

- API endpoint: http://localhost:3000
- Tool: Playwright API request (project `api`)
- Build: nhánh `anh-khoa`, commit `a7b11fd`

Steps to reproduce

Kịch bản 1 — TC-PRODUCT-013 (Không có token — 401):

1. Gửi POST request tạo sản phẩm tới API **không có Authorization header** (không đính kèm token)
2. Kiểm tra response status

Kịch bản 2 — TC-PRODUCT-014 (Token hợp lệ nhưng không phải Admin — 403):

1. Lấy token JWT của tài khoản **Customer** (role != admin) qua API đăng nhập
2. Gửi POST request tạo sản phẩm với token của Customer trong Authorization header
3. Kiểm tra response status

Expected result

- Kịch bản 1: API trả về **401 Unauthorized**
- Kịch bản 2: API trả về **403 Forbidden**

Actual result

API không kiểm tra authentication/authorization, xử lý và trả về response thành công cho cả hai kịch bản.

```
Error: FR-12/SEC-02: phải trả 401 khi không có token
Error: FR-12/SEC-03: phải trả 403 khi token hợp lệ nhưng role != admin
```

Evidence

- Không có screenshot (API test, không có UI)
- Playwright log: **Error: FR-12/SEC-02: phải trả 401 khi không có token**
- Playwright log: **Error: FR-12/SEC-03: phải trả 403 khi token hợp lệ nhưng role != admin**

Notes

Đây là lỗi bảo mật nghiêm trọng (Security Vulnerability). Bất kỳ user nào, kể cả chưa đăng nhập, đều có thể tạo/sửa/xóa sản phẩm thông qua API trực tiếp, bỏ qua giao diện Admin.